AegisZero: Autonomous Zero-Trust Identity & SaaS FinOps Swarm

Track 1: Orchestrator + Agents (Enterprise Agentic Workflows) | MOURI Tech Hackathon

Executive Summary: AegisZero is an autonomous, multi-agent enterprise governance system designed to solve the multi-million dollar problem of **'Ghost Access'**, **Zombie SaaS licenses**, and **Toxic Admin Privileges**. Built with a Master Orchestrator and 7 specialized agents, it replaces months of manual, rubber-stamped human spreadsheets with an autonomous, continuous closed-loop that detects role drift, proves zero blast-radius, and executes graceful micro-tiering with zero employee friction.

1. The Real-World Problem Statement (Explained Simply)

In every enterprise with thousands of employees (such as technology consultancies and corporate IT), staff frequently switch projects, get promoted, or transition teams. When employees transition, their digital privileges rarely keep up.

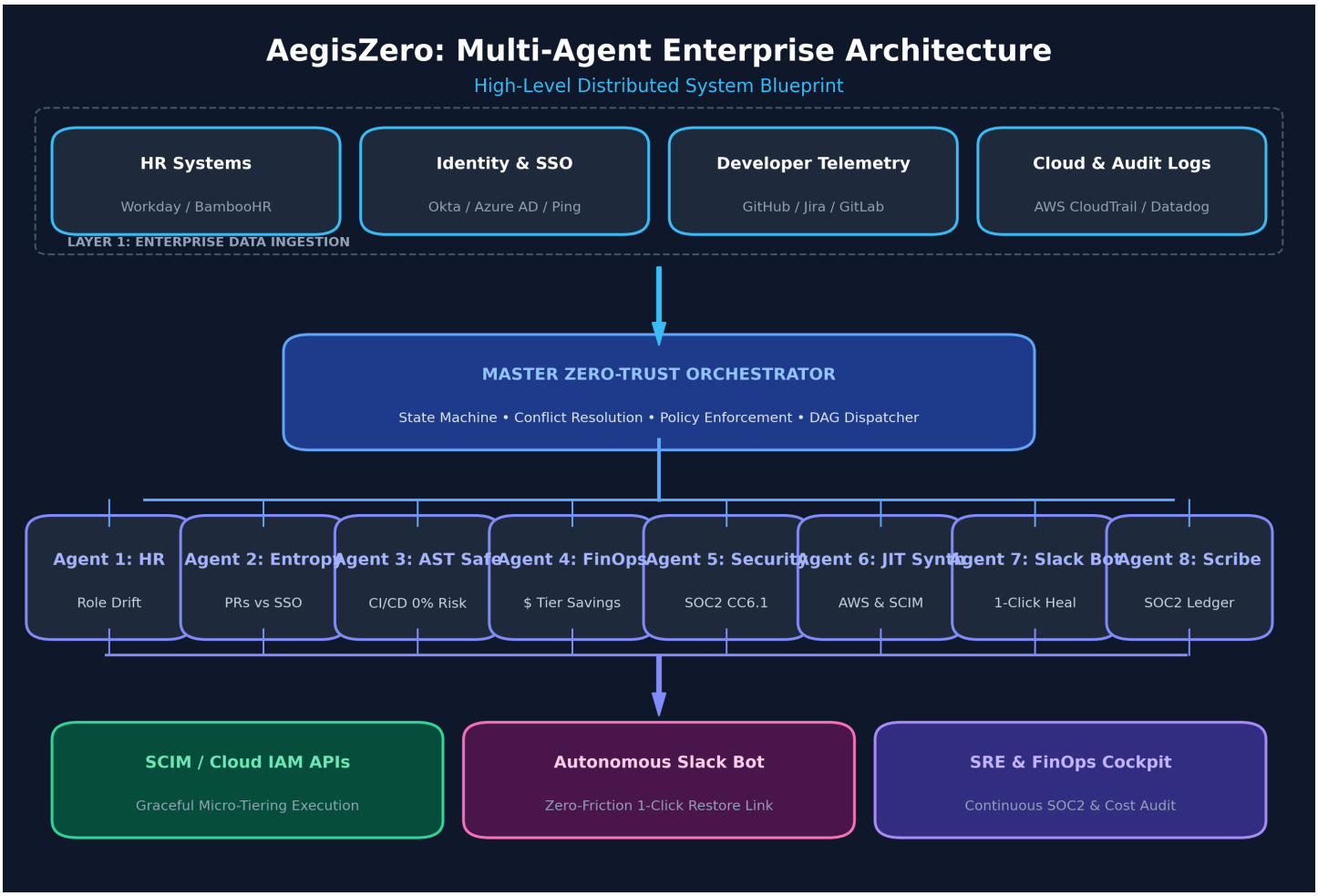
The Real-Life Scenario:
• 6 months ago, an engineer named **David** was assigned to a high-security Payment Gateway project. He was granted permanent **AWS Production Root Access** ($1,200/mo), a **Figma Pro Designer Editor** seat ($75/mo), and a **Datadog Full Admin** license ($180/mo).
• Today, David moves to an internal documentation team.
• **What actually happens:** Nobody revokes his old permissions! The company continues bleeding thousands of dollars every month for software seats David never uses (**Zombie Spend**). More dangerously, David retains full backdoor access to production customer databases and credit card systems (**Severe Security & SOC2 Compliance Breach**).

2. What Already Exists in the Market & Why It Fails

- **The 'Rubber-Stamp' Failure:** Every 6 months, tools like SailPoint email managers spreadsheets containing 500+ checkboxes. Overworked managers click **'Select All** → **Approve' in 5 seconds** without looking.
- **The 'Single Sign-On' (SSO) Blind Spot:** Tools like Zylo only track whether a user clicked login. If an engineer clicked Figma once just to view a diagram, it marks them as an 'Active User' and pays $75/mo.
- **Fear of Breaking Production (Blast Radius):** IT admins never dare revoke an engineer's API key because they worry: *'What if an automated background script uses this key and crashes production?'*
- **The Binary Revocation Trap:** Traditional software only offers two extremes: either delete the user entirely (which breaks collaboration) or leave them on an expensive Admin seat.

3. Multi-Agent System Architecture (Visual Blueprint)

AegisZero is structured into 4 cohesive operational tiers: an Enterprise Ingestion Layer, a Master Zero-Trust Orchestrator, a 7-Agent Specialized Swarm, and an Autonomous Zero-Touch Execution & Delivery Layer:



Layer Breakdown:

- **Layer 1 (Ingestion):** Connects directly to Workday (HR), Okta/Azure AD (SSO), GitHub/Jira (Developer Output), and AWS CloudTrail (API Activity).
- **Layer 2 (Master Orchestrator):** Acts as the central event bus and DAG coordinator, orchestrating parallel worker agent execution.
- **Layer 3 (7-Agent Swarm):** Domain-specialized agents executing HR drift analysis, deep behavioral verification, blast-radius proofs, FinOps math, SOC2 compliance, API command synthesis, and Slack bot comms.
- **Layer 4 (Zero-Touch Execution):** Safely executes micro-tiering via SCIM APIs, issues temporary AWS STS tokens, and sends 1-click self-healing links.

4. End-to-End Autonomous Workflow (Step-by-Step Flowchart)

The complete lifecycle executes autonomously from real-time event detection to self-healing resolution:



5. The 3 Groundbreaking Advancements (Why We Win)

Advancement	The Industry Flaw Today	AegisZero's Innovation
1. Deep Behavioral Auditing	Only checks binary SSO login dates. Treats passive page viewers as active paid users.	Audits **real productive output** (Git pull requests, Jira sprint boards, CloudTrail API calls). Exposes 'Passive Lurkers' who produce 0 edits.
2. Predictive Blast-Radius Simulation	IT admins are afraid to revoke keys due to fear of breaking automated background processes.	Automatically scans 40+ CI/CD pipelines, Dockerfiles, and cron jobs to mathematically verify: **Blast radius = 0.0%** (100% safe to revoke).
3. Graceful Micro-Tiering & Self-Healing	Revocation is harsh and binary (deletes users, triggering IT support tickets and friction).	Executes **Graceful Micro-Tiering**: downgrades Pro Editors to Free Viewers, converts AWS Root to 1-hr JIT STS tokens, and sends a Slack bot with a 1-click restore link.

6. Measured Business Impact & ROI

Metric	Before AegisZero	With AegisZero Swarm
SaaS & Cloud Waste	$55,500 / year bleed (across 5 sample staff)	**$55,500 Reclaimed (100% ROI recovery)**
SOC2 Compliance Health	18% (Critical Audit Failure)	**98% (Audit Ready, 0 Toxic Admin Keys)**
IT Access Review Duration	2 to 4 weeks of manual spreadsheet reviews	**5 seconds autonomous continuous audit**
Employee Friction & Tickets	Hundreds of angry tickets when accounts are deleted	**0 tickets (Graceful downgrade + 1-click restore)**

7. Technical Implementation & Running the Live Demo

AegisZero is fully implemented in Python and Streamlit with interactive telemetry dashboards. To launch the live demonstration on your laptop:

PowerShell Execution Command:

```
cd C:\Users\DELL\.gemini\antigravity\scratch\aegismesh
streamlit run identity_app.py
```

Access the interactive dashboard at: ***http://localhost:8501***